

Code Review Report

ESP32-S3 E-Ink E-Reader - firmware, web UI, build & docs

Scope: end-to-end CSPMO audit (Correctness, Security, Performance, Maintainability, Operational readiness).

Source of truth: src/config.h + src/main.cpp runtime behavior.

Roadmap items reviewed for labeling accuracy, not treated as bugs.

Findings at a glance

- | | | |
|---------------------|----------|---|
| CRITICAL | 1 | Unrestricted file delete via /api/delete (no path validation) |
| SUGGESTION | 5 | Battery underflow, silent upload errors, save churn, doc, bookmark path |
| NICE-TO-HAVE | 4 | Font-size no-op, long-word break, redundant scans, unused define |
| SURFACED | 2 | Hardware-validation doc claim; hardcoded AP password (unchanged) |

1. Executive summary

The firmware is clean, well-layered, and honors the platform's known pitfalls. The single-button gesture state machine, pixel-accurate word-wrap, boot/resume rebuild, light-sleep and Wi-Fi auto-shutoff all match config.h. One Critical security hole exists in the web delete API; the remainder are robustness polish and one stale documentation claim.

Verified correct (no action needed)

- Gesture bands in `handleButtons()` match `BTN_DEBOUNCE_MS=30 / BTN_PREVHOLD_MS=350 / BTN_LONGPRESS_MS=750`, including menu/library tap-move + hold-select and the virtual Wi-Fi row (`g_librarySel==0`).
- `get_text_bounds` is always called with `int32_t` cursor pointers (`textWidth`, `drawTextCentered`) - never literals.
- Battery (ADC2 / GPIO14) is sampled only while the Wi-Fi portal is off; last good value is retained otherwise.
- Full-refresh per reader page (`render -> flush(true)`); GPIO0/GPIO40 never repurposed; PSRAM framebuffer (~253 KB) guarded with a null check.
- `layoutPage` measures the composed line string, preventing right-edge clipping - the documented rationale is correct.
- Docs match code: gesture timings, GPIO map, sleep 120s, Wi-Fi 10min, .txt-only policy, v0.1.0, and the HTTP API table. `secrets.h` is git-ignored and absent. OTA partitions and roadmap items are labeled as planned/later, never as working.

2. Critical

CRITICAL

C1 - /api/delete removes any file on the filesystem (no path validation)

Where: src/web/WebPortal.cpp (POST /api/delete handler)

Why: path is taken verbatim from the query string and passed straight to storage.remove(path). Any client on the AP can delete /bookmarks.json, /settings.json, /www/index.html or (on SD) any absolute path. The upload path is sanitized; delete is not.

Fix: Restrict to a .txt file directly under BOOKS_DIR - no "..", no nested dirs - via a shared isBookPath() helper reused by the bookmark routes (S5). Reject others with HTTP 400.

3. Suggestions

SUGGESTION

S1 - Battery percent underflows for a low battery, reporting 100%

Where: `src/main.cpp readBatteryPercent()`

Why: `mv` is `uint32_t`; below 3300 mV the `(mv - 3300)` subtraction wraps to a huge unsigned value, so after `constrain()` a near-empty battery displays as 100% - the opposite of reality.

Fix: Do the arithmetic signed (`extract batteryPercentFromMv(int)` so it is unit-testable).

SUGGESTION

S2 - Upload handler swallows open/write failures and always returns ok

Where: `src/web/WebPortal.cpp (POST /api/upload)`

Why: If `createForUpload` fails or a write is short (disk full), data is silently dropped and the completion callback still reports success. Violates "no silent catch".

Fix: Track outcome in file-scope statics and respond 500 / ok:false; log the reason. Note the single static `File` handle allows only one upload at a time.

SUGGESTION

S3 - Reading position re-serialized and written to flash on every render

Where: `TextReader::render()` + `BookmarkManager::setLastPosition/save`

Why: Each `render()` re-parses, mutates, re-serializes and rewrites `bookmarks.json` - even on menu-return, bookmark-drop and font-change, which reuse the same offset. That is heap churn in the render path plus needless `LittleFS` wear.

Fix: Skip the persist when the offset is unchanged (minimal). A resident parsed document is a larger, separate refactor.

SUGGESTION

S4 - Web UI tells users to "triple-tap" (no such gesture exists)

Where: `data/www/index.html` ("How to add a book" step)

Why: The device has no triple-tap; opening the library is a long-press -> Library (or you are already in the library when no book is open). Contradicts `handleButtons()` and the README navigation table.

Fix: Reword to the actual hold gestures: long-press to open the menu, choose Library, tap to move, long-press to open a book.

SUGGESTION

S5 - `/api/bookmark` and `/api/bookmarks` accept an arbitrary path

Where: `src/web/WebPortal.cpp (bookmark routes)`

Why: Lower risk than delete (no removal) but an arbitrary path lets a client inflate `bookmarks.json` with keys for non-existent books.

Fix: Gate both routes with the same `isBookPath()` helper from C1.

4. Nice-to-have

- N1 - drawText ignores fontSize: "size 2" titles render at the single FiraSans size (acknowledged TODO; centering uses matching bounds, so cosmetic).
- N2 - A single token wider than usableWidth (~908 px) is placed as-is and clips the right edge, because the wrap check is guarded by line.length(). Rare in prose; a char-break fallback would close it.
- N3 - Redundant listBooks() directory scans on every library navigation (2-3x per redraw). Dominated by the e-ink refresh, so low impact.
- N4 - SETTINGS_FILE is defined in config.h but never referenced.

5. Surfaced for human decision (not changed)

Hardware-validation claims. The README states "v0.1.0 - running on hardware" and that features "all work on the LILYGO T5 4.7" S3". This cannot be verified from code, and the brief says to surface - not silently edit - such claims. Confirm on the bench or soften the wording.

Hardcoded AP password "read1234" (config.h). This is the device's own SoftAP key (publicly documented in the README/manual), not a home-network secret, so it is acceptable to ship. The brief forbids changing the AP auth model or this password without sign-off - no change made.

6. Test opportunities (native pio test)

Pure logic worth covering; enumerated as cases only. Measurement is injected through a stub; storage/JSON is abstracted behind a seam.

Word-wrap (layoutPage core / toAscii)

- Composed-line measurement wraps where summing word+space would under-count.
- A line fitting exactly at maxW does not wrap; one unit over does.
- `\n` forces a break; `\r` is ignored; runs of spaces collapse to one advance.
- Over-wide single token (N2) asserts the documented (unbroken) behavior.
- `toAscii` maps smart quotes / em- & en-dash / ellipsis to ASCII, drops other multibyte, and leaves ASCII byte offsets intact.

Page-offset math

- `nextPage/prevPage` index $\leftrightarrow$ offset round-trip.
- `prevPage` at index 0 and `nextPage` at EOF are no-ops.
- `open()` resume-rebuild reproduces the same boundaries as sequential paging (guards the "stuck page on resume" bug).
- `endOffset` clamps to `_fileSize` with no double-counted deferred word.

Bookmark round-trip

- `setLastPosition` $\rightarrow$ `getLastPosition` (unknown book $\rightarrow$ 0).
- `addBookmark` $\rightarrow$ `listBookmarks` matches offset/label; `removeBookmark` respects bounds.
- `setLastOpenedBook` $\rightarrow$ `getLastOpenedBook`; empty/corrupt JSON loads defaults without crashing.

Validation & helpers

- `isBookPath` accepts `/books/a.txt` and `/books/A.TXT`; rejects `/bookmarks.json`, `/books/../secret`, `/books/sub/a.txt`, `/books/a.bin`, empty name.
- `readBatteryPercent` (post-fix) maps `<3300 mV` $\rightarrow$ 0, `>4200 mV` $\rightarrow$ 100, midpoint $\approx$ 50.
- `humanSize` boundaries at 1 KiB and 1 MiB.